

ResolvX

Cyber Security Policy

Topic-Specific Policy - Network, Endpoint & Cloud Infrastructure Hardening

POL-022 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-022
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A8.1, A8.20, A8.21, A8.22, A8.23, A6.7 · NIST CSF 2.0 PR.IR, PR.PS · SOC 2 CC6.6, CC6.7

1. Purpose

This Cyber Security Policy establishes the technical hardening standards ResolvX applies to its network, endpoints, and cloud infrastructure which is the operational layer that puts the Information Security Policy's commitments into practice at the network and system level.

ResolvX already operates with meaningful technical controls in place; endpoint detection and response on every device, cloud-native threat detection, and a segmented network architecture. This policy formalises the standards those controls are held to and defines the specific hardening practices for network configuration, endpoint posture, and cloud infrastructure that a technical audit or client security review would expect to see documented.

2. Relationship to POL-001

- POL-001 (Information Security Policy) is the apex policy, it establishes the ISMS, ResolvX's overall security commitments, and governance structure across every domain.
- This policy (POL-022) is the technical/operational layer beneath, it specifies the network, endpoint, and cloud infrastructure hardening standards that other topic-specific policies (access, logging, patching) don't individually cover.

3. Scope

This policy applies to:

- ResolvX's AWS network architecture (VPC, subnets, security groups, routing).
- Corporate endpoints (Jamf-managed laptops).
- Cloud infrastructure configuration baseline.
- Remote working connectivity.

4. Network Security

ResolvX's network is segmented by environment. Production, Staging, and Development sit in separate network boundaries, consistent with the asset categories in POL-011. AWS GuardDuty provides continuous threat detection across the network layer, feeding into the monitoring programme under POL-007.

- No Critical-tier data store (per POL-008's Business Impact Analysis) is directly exposed to the public internet and access routes through the application layer or a bastion/VPN path, never a direct public database or storage endpoint.
- Security group rules follow least-privilege by default where a new rule opening broader access than a specific is documented and need requires Head of Cloud Ops approval as part of the change process under POL-013.
- Security group configuration is included in the quarterly reconciliation already required under POL-011 §7.1, specifically checking for unintended public exposure.
- Administrative access to production infrastructure occurs through a controlled path (VPN or bastion), not direct public SSH/RDP exposure.

5. Endpoint Security

Every corporate laptop runs Jamf MDM with Endpoint Detection and Response (EDR) active, consistent with the requirements already set in POL-002. This policy defines the baseline those tools enforce:

- Full-disk encryption is mandatory and enforced through Jamf where a device found without it active is treated as non-compliant and blocked from accessing corporate resources until remediated.
- Screen lock activates after a maximum of 10 minutes of inactivity.
- EDR and MDM agents must remain active. A tamper or disable event generates an alert to IT Admin, consistent with the log pipeline health principle in POL-007 §6.2 applied to endpoint telemetry specifically.
- Non-corporate (personal) devices do not access Restricted-tier systems, consistent with POL-002.

6. Cloud Infrastructure Hardening

ResolvX's AWS environment is configured against the CIS AWS Foundations Benchmark as a reference baseline, rather than an ad hoc configuration standard.

- Public S3 bucket access is disabled by default at the account level; a bucket requiring public access needs a documented business justification and Head of Cloud Ops approval.
- IAM follows least-privilege where broad or wildcard permissions require the same change approval as any other high-blast-radius change under POL-013 §3.
- The DLP roadmap's Stage 2 (POL-019 §5) extends this hardening baseline with automated data discovery and public-exposure alerting for S3 specifically.

7. Remote Working

ResolvX operates as a remote-capable organisation; this section formalises the security expectations that come with that model:

- Corporate systems are accessed only from ResolvX-managed devices meeting the endpoint standard in §5.
- Access to Restricted-tier systems from an unsecured public network (e.g., open public WiFi) requires the corporate VPN or an equivalent secure tunnel. Direct access is not permitted.
- Personnel working from a shared or public space follow the same discretion expectations already set in POL-004 §5.3 for verbal and visual confidentiality.

8. Roles & Responsibilities

9.1 Head of Cloud Ops

- Owns this policy, the network architecture (§4), and the cloud hardening baseline (§6).

9.2 IT Admin

- Maintains the endpoint security baseline (§5) and responds to EDR/MDM tamper alerts.

9.3 DevSecOps

- Reviews IAM and security group changes for least-privilege adherence as part of change review under POL-013.

9. Compliance and Enforcement

A publicly exposed Critical-tier data store, a device found with disabled encryption or EDR, or a security group change bypassing the review in §4 is treated as a control deficiency and logged in the Corrective Action Plan.

10. Document Control

Policy ID	POL-022
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A6.7, A8.1, A8.20, A8.21, A8.22, A8.23 · NIST CSF 2.0 PR.IR, PR.PS · SOC 2 TSC CC6.6, CC6.7
Related Documents	POL-001 (Information Security Policy), POL-002 (Acceptable Use Policy), POL-007 (Logging & Monitoring Policy), POL-011 (Asset Management Policy), POL-013 (Change Management Policy), POL-019 (DLP Policy)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		